

↳

Ci sono 2 o più agenti che si scambiano messaggi $A, B, \dots$. Vogliamo essere sicuri che i messaggi siano creati solo da loro, non tanto dalla loro segretezza.

Si sceglie una funzione pseudocasuale f da condividere tra gli agenti. Si aggiunge ad ogni messaggio m il valore $f(m)$. Si spedisce la coppia $(m, \underbrace{f(m)}_{\text{autenticazione di } m})$.

$$m = m_1 \ m_2 \ m_3 \ \dots \ m_f$$

↳ m su random

Forger $F \in \text{PPR}$ che si fa firmare un numero arbitrario di messaggi (tenta di contraffare un messaggio autenticato) $m_1, m_2, \dots, m_\ell$ e produce una coppia (m, σ) . Diciamo che F ha successo se $\sigma = f(m)$ e $\forall i$ $m \neq m_i$.

$$\forall f \in \text{PPR} \quad \Pr [f \text{ ha successo}] < k^{-u(n)}$$

Il forger cercherà di generare una coppia (m, σ) t.c.

- il messaggio m non sia mai stato autenticato precedentemente
- σ sia corretto per quel messaggio m ($\sigma = f(m)$)

m è un messaggio nuovo, non è uno di quelli che ha richiesto di autenticare.

↳ COME AUTENTICARE MESSAGGI DI LUNGHEZZA ARBITRARIA?

$n = m_1 m_2 \dots m_l$ Scomponiamo in blocchi di n bit

$$f(m) = f(m_1) \oplus f(m_2) \oplus \dots \oplus f(m_l)$$

Questo sistema ha il difetto dei scambi di messaggi. Esiste un forger?

Ad esempio se io chiedo $f(m_1, m_2)$ la corr. $(m_2, m_1, f(m_1, m_2))$ è autentica.
Posso anche costruire un forger sendo interrogare f

$$f(m_1 m_2) \Rightarrow f(m_1) \oplus f(m_2) = 0 \quad // \text{ solo se n° blocchi } \bar{e} \text{ pari}$$

↳ VOGLIAMO EVITARE LO SCAMBIO DI MESSAGGI

$$f(m) = f(c_1, m_1) \oplus f(c_2, m_2) \oplus \dots \oplus f(c_l, m_l)$$

Il numeretto aggiunto indica la posizione del blocco nella stringa. Ora se scambiasse l'ordine dei blocchi otterremo autenticazione diversa. Ad esempio

$$f(\langle 1 \rangle m_2) \oplus f(\langle 2 \rangle m_1) \oplus \dots$$

Inoltre non funziona più

$$f(\langle 1 \rangle_{n_1}, \langle 2 \rangle_{n_1}) \neq 0$$

↳ È SICURO? ESISTE O NON ESISTE IL FORSER?

Costruiamo un messaggio del genere

$$f(m_1, m_2) = \cancel{f(s, m_1)} \oplus \cancel{f(s, m_2)}$$

$$f(m_1', m_2) = f(c_1, m_1') \oplus f(c_2, m_2)$$

$$F(m_1, m_2') = f(\cancel{c_1}, m_1) \oplus f(c_2, m_2')$$

1. IRE MESSAGGI DISTINTI

④ $\rightarrow$ xor di tutte le autenticazioni date

$$f(m_1', m_2') \quad f(\langle 1 \rangle m_1') \oplus f(\langle 2 \rangle m_2')$$

è l'autenticazione corretta di un nuovo messaggio mai autenticato prima

↳ PROVANDO AD UTILIZZARE LO XOR MODIFICATO

$$F(x_1, \dots, x_n) \triangleq f(x_n \oplus f(x_{n-1} \oplus f(x_{n-2} \oplus \dots \oplus f(x_2 \oplus f(x_1)))))) \quad \text{questo è sicuro}$$

$$f : \{0,1\}^{kl} \longrightarrow \{0,1\}^k$$

$$F(x_1, x_2, \dots, x_n) = f(x_n \oplus \dots f(x_3 \oplus f(x_2 \oplus f(x_1))) // \text{PSEUDO CASUAL}$$

↳ NON REPUDIATION

Vogliamo un meccanismo che impedisce ad un agente di negare l'autenticazione dei messaggi (propri e degli altri)

↳ FIRMA DIGITALE

Chi si verifica la correttezza di una firma, non deve essere in grado di farla. Solamente la persona che firma deve essere in grado di generare la firma, chi verifica non deve essere in grado di firmare.

Solo uno (o pochi) agente(i) può(ono) firmare, tutti possono verificare la firma. (HI) può VERIFICARE non può FIRMARE

Devono esistere due "sem" (chiavi)

PR) V.A. → PER FIRMARE
 PUBBLICA → PER VERIFICARE

} dalla chiave pubblica non si può ottenere la chiave privata

rsa

PRIVATA PER FIRMARE	(n, j)
PUBBLICA PER VERIFICARE	(n, l)

$$(m, m^d)$$

$$(m, \sigma) \rightarrow \sigma^{\ell} \stackrel{?}{=} m \quad (m^d)^e = m^{ed} = m^{k \phi(n) + 1} = m$$

b) COME DIMOSTRARE LA CORRETTEDD

RSA $\rightarrow (m, (m^d))$ solo la chi. ha la chiave privata genera questo
 $\downarrow$
 $c(m)$

$$(m^d)^l = m$$

↳ CHE COS'È UNO SCHEMA DI FIRMA DIGITALE, DI CRYPTOGRAFIA?

```

graph TD
    GSV[G, S, V] --> generate
    GSV --> sign
    GSV --> verify

```

$G : \gamma^k \longrightarrow (S_k, p_k)$ // chiavi	(m, m_d)
$S : m, S_k \longrightarrow \sigma(m)$ // firma	$x^k \stackrel{?}{=} m$
$V : m, \sigma, p_k \longrightarrow \{0, 1\}$ // accettazione	$(x^k, x) \longrightarrow$ il falsificatore per non esiste

• 4m $\Pr [V(m, s(m, s_k), p_k) = 1] = 1$ la probabilità che la verifica di un messaggio autenticato usando l'algoritmo S dia ok deve essere 1

sia F e per un algoritmo che chiede la firma di messaggi $m_1, m_2, \dots, m_l$, anche in modo adattivo, e che produce una coppia (m, σ)

F ha successo se $V(pk, m, \sigma) = 1$ and $\forall i, m \neq m_i$ // firma falsa non fatta dal possessore della chiave privata

$\forall F \in \text{PR}$ $\Pr[F \text{ ha successo}] < n^{-u(n)}$

(m_1, m_1^d)

(m_2, m_2^d)

$(m_1 \cdot m_2, m_1^d \cdot m_2^d)$

$(m_1 m_2)^d$

(m^e, m)

RSA non è corretto secondo la definizione sopra

↳ COME FIRMAMO MESSAGGI LUNGI

↳ FUNZIONI HASH

$\sigma(m) = H(m)^d$ // si firma l'hash del messaggio, non il messaggio. Questo per evitare di firmare messaggi troppo lunghi, vogliamo firmare n bit

• il caso è se esiste $H(m') = H(m)$

chiedo σ firma di m } $\sigma = H(m)^d$
 produco (m', σ) } FORGER
 σ è una firma valida per m'

• hanno collisioni

↳ SOLUZIONE ALLE COLLISIONI

H COLLISION RESISTANT $\rightarrow$ è difficile trovare una collisione

↳ NE ESISTONO?

- SHA-1
- ma sono state proposte
- MD $\rightarrow$ message digest
- SHA-2
- ↳ non sono ancora state trovate collisioni

↳ HASH ONE WAY

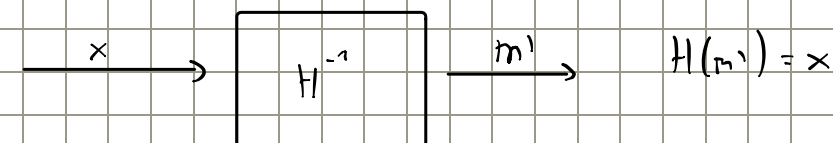
H è one-way se dato x è difficile trovare un qualsiasi m t.c. $H(m) = x$

Se H è collision resistant allora H è one way

↳ DIM

Supponiamo che H non sia one-way, mostriamo che H non è collision resistant

prendiamo m messaggio casuale
 calcoliamo $x = H(m)$



- Qual è la probabilità che $m = m'$?
 - avendo scelto m a caso ad esempio 1000 bit, allora la probabilità che $m' = m$ è $\frac{1}{2^{1000}}$
- ↳ sulla cardinalità dei messaggi che vanno in collisione

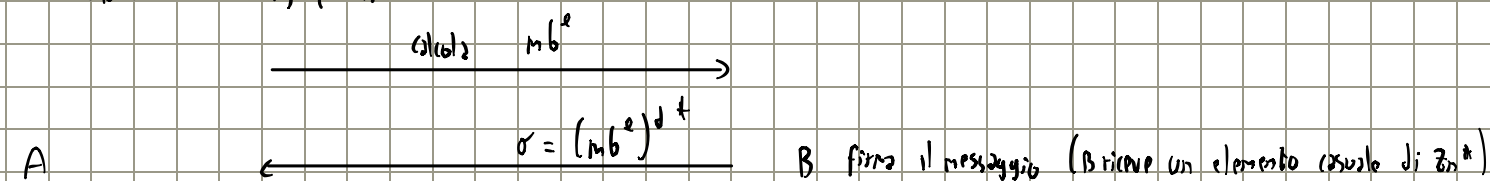
Rad 9,33263618503219e-302 $1 \div 2^{1000}$

- praticamente 0, quindi con probabilità sostanzialmente 1 ho trovato una collisione
- quindi una funzione H COLLISION RESISTANT è più robusta di una f ONE-WAY

↳ BLIND SIGNATURE (come possiamo firmare un messaggio di cui non conosciamo il contenuto?)

A ha un messaggio m che B deve firmare

$b \in \mathbb{Z}_n^*$ // blinding factor



calcola $\sigma^- = \sigma / b$

PRODUCE (m, σ^-)

↳ $\sigma^- = \sigma \cdot b^{-1} = (m b^e)^d \cdot b^{-1} = m^d b^{ed} b^{-1} = m^d \cdot \cancel{b^e} \cdot \cancel{b^{-1}} = m^d$ // firma di m

• come può BOB avere la garanzia che il messaggio m sia ben firmato

1) la chiave pubblica usata da BOB, può essere usata solo per spedire o/r

2) complichiamo leggermente il protocollo

A genera $m_1, \dots, m_l$ differenti } messaggi identici ma differiscono per PIN $\rightarrow$ scelto a caso
messaggi di comunicazione PIN

A genera $b_1, \dots, b_l$ BLINDING FACTORS
A spedisce $m_1 b_1^e, \dots, m_l b_l^e$ A BOB

B scegli $i \in \{1, \dots, l\}$ una lettera e comunica i ad A

$m_i b_i^e, \dots, m_l b_l^e$
 $\uparrow$
 i

A comunica $m_1 b_1, m_2 b_2, \dots, m_{i-1} b_{i-1}, m_{i+1} b_{i+1}, \dots, m_l b_l$

• in pratica A comunica tutte le info tranne il messaggio e blinding factor i -esimo

B verifica la correttezza dei dati ricevuti. Se la verifica ha successo produce la firma $(m_i b_i^e)^d$

Altrimenti $\dots$ è dura

ESEMPIO SE DA UNA FIRMA ERRATA BOB PERDE 1000 EURO
SE $l = 10$
CHE SANZIONE DEVE PREVEDERE BOB PER NON PERDERE?

$$P_{\text{noL}} = \frac{2}{10} x - \frac{1}{10} 1000 \geq 0$$

$$2x - 1000 \geq 0$$

$$x \geq \frac{1000}{2} = 500 \dots$$

SE BOB FISSA LA SANZIONE A 500 EURO, ALLORA CI GUARDAVA